

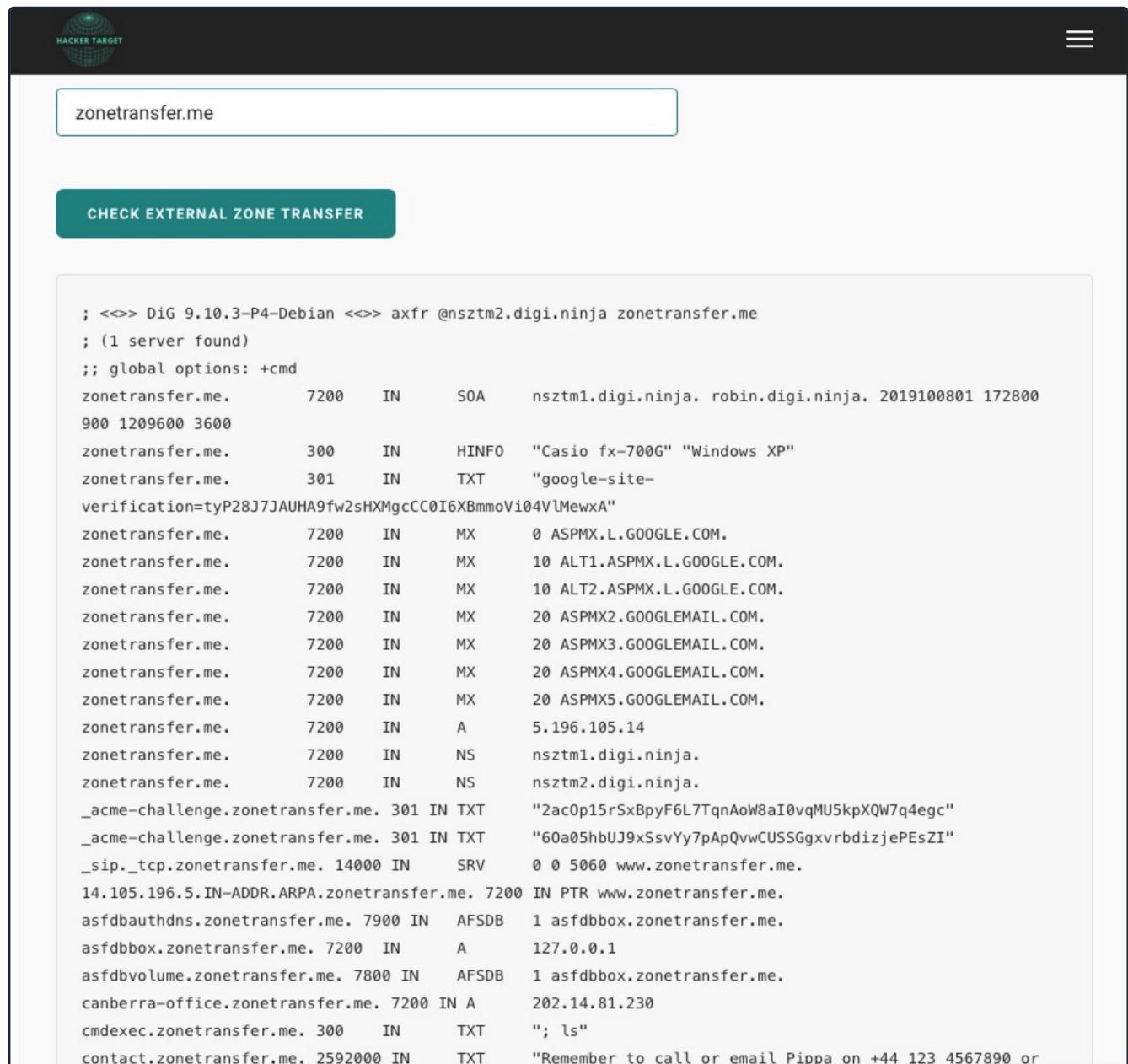
Active Subdomain Enumeration

We can perform active subdomain enumeration probing the infrastructure managed by the target organization or the 3rd party DNS servers we have previously identified. In this case, the amount of traffic generated can lead to the detection of our reconnaissance activities.

ZoneTransfers

The zone transfer is how a secondary DNS server receives information from the primary DNS server and updates it. The master-slave approach is used to organize DNS servers within a domain, with the slaves receiving updated DNS information from the master DNS. The master DNS server should be configured to enable zone transfers from secondary (slave) DNS servers, although this might be misconfigured.

For example, we will use the <https://hackertarget.com/zone-transfer/> service and the zonetransfer.me domain to have an idea of the information that can be obtained via this technique.



The screenshot shows the zonetransfer.me website interface. At the top, there is a search bar containing the domain "zonetransfer.me". Below the search bar is a green button labeled "CHECK EXTERNAL ZONE TRANSFER". The main content area displays the output of a DNS zone transfer query performed using the dig command. The output shows various DNS records for the domain zonetransfer.me, including SOA, HINFO, TXT, MX, A, NS, SRV, and PTR records.

```
; <> DiG 9.10.3-P4-Debian <> axfr @nsztml.digi.ninja zonetransfer.me
; (1 server found)
;; global options: +cmd
zonetransfer.me.      7200    IN      SOA      nsztml.digi.ninja. robin.digi.ninja. 2019100801 172800
900 1209600 3600
zonetransfer.me.      300     IN      HINFO    "Casio fx-700G" "Windows XP"
zonetransfer.me.      301     IN      TXT      "google-site-
verification=tyP28J7JAUHA9fw2sHXMgcCC0I6XBmmoVi04VLMewxA"
zonetransfer.me.      7200    IN      MX       0 ASPMX.L.GOOGLE.COM.
zonetransfer.me.      7200    IN      MX       10 ALT1.ASPMX.L.GOOGLE.COM.
zonetransfer.me.      7200    IN      MX       10 ALT2.ASPMX.L.GOOGLE.COM.
zonetransfer.me.      7200    IN      MX       20 ASPMX2.GOOGLEMAIL.COM.
zonetransfer.me.      7200    IN      MX       20 ASPMX3.GOOGLEMAIL.COM.
zonetransfer.me.      7200    IN      MX       20 ASPMX4.GOOGLEMAIL.COM.
zonetransfer.me.      7200    IN      MX       20 ASPMX5.GOOGLEMAIL.COM.
zonetransfer.me.      7200    IN      A        5.196.105.14
zonetransfer.me.      7200    IN      NS       nsztml.digi.ninja.
zonetransfer.me.      7200    IN      NS       nsztml.digi.ninja.
_acme-challenge.zonetransfer.me. 301 IN TXT "2ac0p15rSxBpyF6L7TqnAoW8aI0vqMU5kpXQW7q4egc"
_acme-challenge.zonetransfer.me. 301 IN TXT "60a05hbUJ9xSsvYy7pApQvwCUSGgXvrbdzjePEsZI"
_sip._tcp.zonetransfer.me. 14000 IN SRV 0 0 5060 www.zonetransfer.me.
14.105.196.5.IN-ADDR.ARPA.zonetransfer.me. 7200 IN PTR www.zonetransfer.me.
asfdbauthdns.zonetransfer.me. 7900 IN AFSDB 1 asfdbbox.zonetransfer.me.
asfdbbox.zonetransfer.me. 7200 IN A 127.0.0.1
asfdbvolume.zonetransfer.me. 7800 IN AFSDB 1 asfdbbox.zonetransfer.me.
canberra-office.zonetransfer.me. 7200 IN A 202.14.81.230
cmdexec.zonetransfer.me. 300 IN TXT ";" ls"
contact.zonetransfer.me. 2592000 IN TXT "Remember to call or email Pippa on +44 123 4567890 or
```

pippa@zonetransfer.me when making DNS changes"

A manual approach will be the following set of commands:

1. Identifying Nameservers

1. Identifying Nameservers

```
dbcypth0n@htb[/htb]$ nslookup -type=NS zonetransfer.me

Server:      10.100.0.1
Address:     10.100.0.1#53

Non-authoritative answer:
zonetransfer.me nameserver = nsztml.digi.ninja.
zonetransfer.me nameserver = nsztml.digi.ninja.
```

2. Perform the Zone transfer using `-type=any` and `-query=AXFR` parameters

2. Testing for ANY and AXFR Zone Transfer

2. Testing for ANY and AXFR Zone Transfer

```
dbcypth0n@htb[/htb]$ nslookup -type=any -query=AXFR zonetransfer.me nsztml.digi.ninja

Server:      nsztml.digi.ninja
Address:     81.4.108.41#53

zonetransfer.me
  origin = nsztml.digi.ninja
  mail addr = robin.digi.ninja
  serial = 2019100801
  refresh = 172800
  retry = 900
  expire = 1209600
  minimum = 3600
zonetransfer.me hinfo = "Casio fx-700G" "Windows XP"
zonetransfer.me text = "google-site-verification=tyP28J7JAUHA9fw2sHXMgcCC0I6XBmmoVi04VLMewxA"
zonetransfer.me mail exchanger = 0 ASPMX.L.GOOGLE.COM.
zonetransfer.me mail exchanger = 10 ALT1.ASPMX.L.GOOGLE.COM.
zonetransfer.me mail exchanger = 10 ALT2.ASPMX.L.GOOGLE.COM.
zonetransfer.me mail exchanger = 20 ASPMX2.GOOGLEMAIL.COM.
zonetransfer.me mail exchanger = 20 ASPMX3.GOOGLEMAIL.COM.
zonetransfer.me mail exchanger = 20 ASPMX4.GOOGLEMAIL.COM.
zonetransfer.me mail exchanger = 20 ASPMX5.GOOGLEMAIL.COM.
Name:      zonetransfer.me
Address: 5.196.105.14
zonetransfer.me nameserver = nsztml.digi.ninja.
zonetransfer.me nameserver = nsztml.digi.ninja.
_acme-challenge.zonetransfer.me text = "60a05hbUJ9xSsvYy7pApQvwCUSSGgxvrbdzjePEsZI"
_sip._tcp.zonetransfer.me service = 0 0 5060 www.zonetransfer.me.
14.105.196.5.IN-ADDR.ARPA.zonetransfer.me name = www.zonetransfer.me.
asfdbauthdns.zonetransfer.me afsdb = 1 asfdbbox.zonetransfer.me.
Name:      asfdbbox.zonetransfer.me
Address: 127.0.0.1
asfdbvolume.zonetransfer.me afsdb = 1 asfdbbox.zonetransfer.me.
Name:      canberra-office.zonetransfer.me
Address: 202.14.81.230
cmdexec.zonetransfer.me text = "; ls"
contact.zonetransfer.me text = "Remember to call or email Pippa on +44 123 4567890 or pippa@zonetransfer.me w
Name:      dc-office.zonetransfer.me
Address: 143.228.181.132
Name:      deadbeef.zonetransfer.me
Address: dead:beaf::
dr.zonetransfer.me loc = 53 20 56.558 N 1 38 33.526 W 0.00m 1m 10000m 10m
DZC.zonetransfer.me text = "AbCdEfG"
email.zonetransfer.me naptr = 1 1 "P" "E2U+email" "" email.zonetransfer.me.zonetransfer.me.
Name:      email.zonetransfer.me
```

```

Address: 74.125.206.26
Hello.zonetransfer.me    text = "Hi to Josh and all his class"
Name:    home.zonetransfer.me
Address: 127.0.0.1
Info.zonetransfer.me text = "ZoneTransfer.me service provided by Robin Wood - robin@digi.ninja. See http://digi.ninja.me
internal.zonetransfer.me nameserver = intns1.zonetransfer.me.
internal.zonetransfer.me nameserver = intns2.zonetransfer.me.
Name:    intns1.zonetransfer.me
Address: 81.4.108.41
Name:    intns2.zonetransfer.me
Address: 167.88.42.94
Name:    office.zonetransfer.me
Address: 4.23.39.254
Name:    ipv6actnow.org.zonetransfer.me
Address: 2001:67c:2e8:11::c100:1332
Name:    owa.zonetransfer.me
Address: 207.46.197.32
robinwood.zonetransfer.me    text = "Robin Wood"
rp.zonetransfer.me    rp = robin.zonetransfer.me. robinwood.zonetransfer.me.
sip.zonetransfer.me    naptr = 2 3 "P" "E2U+sip" "!^.*$!sip:customer-service@zonetransfer.me!" .
sqli.zonetransfer.me    text = "' or 1=1 --"
sshock.zonetransfer.me    text = "() { :|}; echo ShellShocked"
staging.zonetransfer.me    canonical name = www.sydneyoperahouse.com.
Name:    alltcpportsopen.firewall.test.zonetransfer.me
Address: 127.0.0.1
testing.zonetransfer.me    canonical name = www.zonetransfer.me.
Name:    vpn.zonetransfer.me
Address: 174.36.59.154
Name:    www.zonetransfer.me
Address: 5.196.105.14
xss.zonetransfer.me    text = "'><script>alert('Boo')</script>"
zonetransfer.me
    origin = nsztml.digi.ninja
    mail addr = robin.digi.ninja
    serial = 2019100801
    refresh = 172800
    retry = 900
    expire = 1209600
    minimum = 3600

```

If we manage to perform a successful zone transfer for a domain, there is no need to continue enumerating this particular domain as this will extract all the available information.

Gobuster

Gobuster is a tool that we can use to perform subdomain enumeration. It is especially interesting for us the patterns options as we have learned some naming conventions from the passive information gathering we can use to discover new subdomains following the same pattern.

We can use a wordlist from [Seclists](#) repository along with [gobuster](#) if we are looking for words in patterns instead of numbers.

Remember that during our passive subdomain enumeration activities, we found a pattern `lert-api-shv-{NUMBER}-sin6.facebook.com`. We can use this pattern to discover additional subdomains. The first step will be to create a patterns.txt file with the patterns previously discovered, for example:

GoBuster - patterns.txt

GoBuster - patterns.txt

```

lert-api-shv-{GOBUSTER}-sin6
atlas-pp-shv-{GOBUSTER}-sin6

```

The next step will be to launch [gobuster](#) using the [dns](#) module, specifying the following options:

- **dns**: Launch the DNS module
- **-q**: Don't print the banner and other noise.
- **-r**: Use custom DNS server
- **-d**: A target domain name
- **-p**: Path to the patterns file
- **-w**: Path to the wordlist
- **-o**: Output file

In our case, this will be the command.

Gobuster - DNS

Gobuster - DNS

```
dbcypn@htb[/htb]$ export TARGET="facebook.com"
dbcypn@htb[/htb]$ export NS="d.ns.facebook.com"
dbcypn@htb[/htb]$ export WORDLIST="numbers.txt"
dbcypn@htb[/htb]$ gobuster dns -q -r "${NS}" -d "${TARGET}" -w "${WORDLIST}" -p ./patterns.txt -o "gobuster_

Found: lert-api-shv-01-sin6.facebook.com
Found: atlas-pp-shv-01-sin6.facebook.com
Found: atlas-pp-shv-02-sin6.facebook.com
Found: atlas-pp-shv-03-sin6.facebook.com
Found: lert-api-shv-03-sin6.facebook.com
Found: lert-api-shv-02-sin6.facebook.com
Found: lert-api-shv-04-sin6.facebook.com
Found: atlas-pp-shv-04-sin6.facebook.com
```

We can now see a list of subdomains appearing while Gobuster is performing the enumeration checks.

VPN Servers

 **Warning:** Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

us-academy-1

PROTOCOL

 UDP 1337  TCP 443

DOWNLOAD VPN CONNECTION FILE

Start Instance

 / 1 spawns left

Waiting to start...

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target: **Target is spawning...**



Cheat Sheet

Download VPN
Connection File**+ 1** 

Submit the FQDN of the nameserver for the "inlanefreight.htb" domain as the answer.

Submit your answer here...

 Submit**+ 1** 

Identify how many zones exist on the target nameserver. Submit the number of found zones as the answer.

Submit your answer here...



Submit



Hint

+ 1 

Find and submit the contents of the TXT record as the answer.

Submit your answer here...



Submit



Hint

+ 1 

What is the FQDN of the IP address 10.10.34.136?

Submit your answer here...

 Submit**+ 1** 

What FQDN is assigned to the IP address 10.10.1.5? Submit the FQDN as the answer.

Submit your answer here...

 Submit

+ 1 🟢 Which IP address is assigned to the "us.inlanefreight.htb" subdomain. Submit the IP address as the answer.

Submit your answer here...

Submit

+ 1 🟢 Submit the number of all "A" records from all zones as the answer.

Submit your answer here...

Submit

Hint

← Previous

Next →

Cheat Sheet

? Go to Questions

Table of Contents

Information Gathering



Passive Information Gathering

🟢 WHOIS



🟢 DNS



Passive Subdomain Enumeration



Passive Infrastructure Identification



Active Information Gathering

🟢 Active Infrastructure Identification



🟢 [Active Subdomain Enumeration](#)

🟢 Virtual Hosts

Crawling

Putting it all Together

🟢 Information Gathering - Web - Skills Assessment

My Workstation

OFFLINE

▶ Start Instance

∞ / 1 spawns left

